AMRITA VISHWA VIDYAPEETHAM

School of Engineering • Chennai Campus

SOFTWARE REQUIREMENTS SPECIFICATION

& SECURE SYSTEM DESIGN

SmartWaste Secure

IoT-Based Smart Waste Management Platform

Document	Phase 2 - SRS + Connected Design Baseline
Course	24CYS401 - Secure Software Engineering
Examination	End Semester Laboratory Examination
Prepared by	Yeshwanth Raj
Register Number	CH.SC.U4CYS23052
Version	1.0
Date	08 October 2026

SYSTEM SECURITY FOCUS

Sensor spoofing • location manipulation • unauthorized route modification • availability • device authentication • API security

1. Requirements Baseline

The platform collects telemetry from smart bins, validates and stores the data, detects suspicious sensor activity, generates optimized collection routes, and allows authorized administrators to assign vehicles and drivers. The design baseline below is intended to remain consistent through UML, ER/DFD, threat modeling, implementation, testing and deployment.

1.1 Stakeholders

Actor	Role / Goal	Security Responsibility
Administrator	Manage bins, routes, vehicles, drivers and security settings.	Strong authentication, least privilege and audited privileged actions.
Driver	View assigned routes and update collection status.	Only authorized operational data.
System Operator	Monitor system and device health.	Operational visibility without unnecessary admin privilege.
Security Auditor	Review security events and evidence.	Read-only security/audit access.
Smart Bin	Send periodic telemetry.	Authenticate before telemetry is accepted.

1.2 Functional Requirements

ID	Requirement	Priority
FR-01	Administrator shall authenticate before accessing protected functions.	Critical
FR-02	Administrator shall register and manage smart bins.	High
FR-03	Smart bins shall authenticate before telemetry submission.	Critical
FR-04	System shall receive fill level, location, temperature and sensor status.	Critical
FR-05	System shall validate telemetry schema, type and ranges.	Critical
FR-06	System shall store telemetry with timestamp and device association.	High
FR-07	System shall display bin status and operational alerts.	High
FR-08	System shall identify suspicious or anomalous telemetry.	Critical
FR-09	System shall generate optimized collection routes.	Critical
FR-10	Administrator shall assign vehicles and drivers to routes.	High
FR-11	Driver shall view assigned route and collection sequence.	High
FR-12	Administrator shall modify/cancel routes subject to authorization.	Critical
FR-13	System shall maintain security-relevant audit records.	High
FR-14	System shall generate security alerts for important anomalies and unauthorized actions.	High

2. Non-Functional & Security Requirements

2.1 Non-Functional Requirements

ID	Category	Requirement	Acceptance Target
NFR-01	Security	External protected API traffic shall use TLS.	No plaintext protected traffic.
NFR-02	Security	Protected operations shall enforce authentication and RBAC.	Server-side checks on protected endpoints.
NFR-03	Availability	Core service should remain available during normal lab load.	Health checks and graceful errors.
NFR-04	Performance	Telemetry ingestion shall not block normal UI operations.	Efficient processing path.
NFR-05	Scalability	Services shall be container-ready.	Docker/Kubernetes compatible.
NFR-06	Maintainability	Business logic shall be separated from API/data access.	Service/repository structure.
NFR-07	Auditability	Security-sensitive actions shall be traceable.	Actor/device, action, resource, timestamp and outcome.
NFR-08	Usability	Dashboard shall show status, warnings and errors clearly.	Consistent navigation and feedback.
NFR-09	Reliability	Invalid telemetry shall not corrupt stored data.	Validation before persistence.
NFR-10	Portability	Application shall run in a local containerized lab.	Docker + Minikube.

2.2 Security Requirements

ID	Requirement	Primary Property
SR-01	Each registered smart bin shall possess an authenticated device identity.	Authentication / Integrity
SR-02	Sensitive API endpoints shall enforce authentication.	Confidentiality
SR-03	RBAC shall restrict route, vehicle, driver and audit operations.	Authorization
SR-04	Telemetry shall undergo schema, type, range and consistency validation.	Integrity
SR-05	Location data shall be checked for impossible values and suspicious movement.	Integrity
SR-06	Route modifications shall require explicit authorization and create an audit event.	Integrity / Accountability
SR-07	API requests shall be rate-limited.	Availability
SR-08	Secrets shall be externalized, never hard-coded.	Confidentiality
SR-09	Database access shall follow least privilege.	Confidentiality / Integrity
SR-10	Failed authentication, privilege changes and anomalies shall be logged.	Accountability
SR-11	Error responses shall not expose credentials, tokens or stack traces.	Confidentiality
SR-12	Containers shall run without unnecessary privileges.	Defense in depth

3. Hardware, Sensors & IoT Device

Important scope note: the supplied problem statement specifies the four telemetry outputs but does not prescribe exact electronic part numbers. The following is therefore the proposed laboratory prototype hardware baseline used by this design.

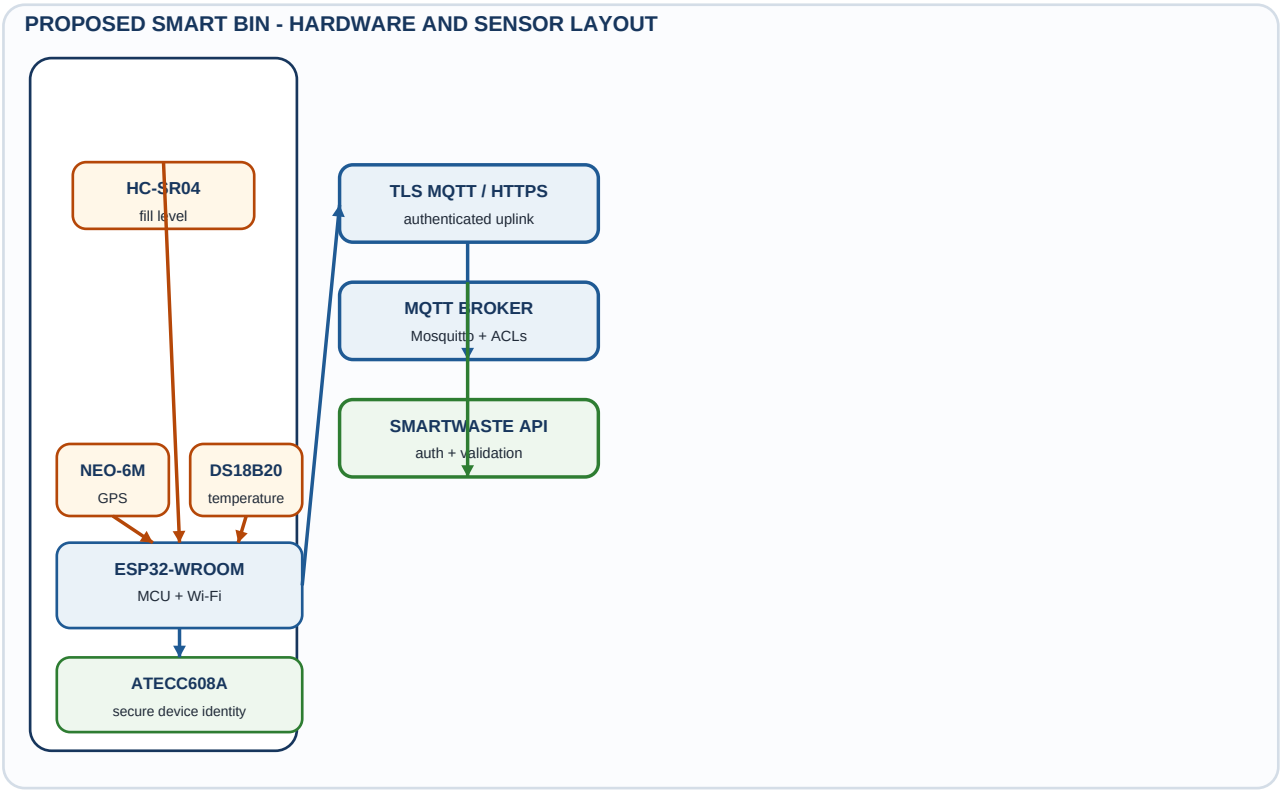

Figure 1. Proposed smart-bin hardware and secure telemetry path.

Hardware / Module	Purpose	System Data / Function	Security / Design Role
ESP32-WROOM	Edge controller + Wi-Fi.	Reads sensors; packages and transmits telemetry.	Restrict firmware features; no hard-coded secrets.
HC-SR04 Ultrasonic	Measure distance to waste surface.	Distance converted to fill-level %.	Server validates range and plausibility.
NEO-6M GPS	Provide geographic coordinates.	Latitude / longitude.	Bounds + historical/anomaly checks.
DS18B20	Temperature measurement.	Temperature (°C).	Type/range/plausibility validation.
ATECC608A Secure Element	Hardware-backed cryptographic identity.	Private-key/certificate operations.	Keep device key material protected; strengthen device authentication.
5V Regulated Power	Power the prototype electronics.	Stable supply.	Enclosed/protected power and brownout health signal.
Prototype Enclosure	Physical protection for electronics.	Physical housing.	Restrict direct access/tampering.
MQTT Broker (Mosquitto)	Laboratory message broker.	Device telemetry topics.	Topic/device ACLs; authenticated broker access.

3.1 Sensor-to-Requirement Mapping

Problem Statement Output	Source	Processing	Stored Field
Fill level	HC-SR04	Distance → percentage + range validation	fill_level
Location	NEO-6M	Coordinate validation + anomaly detection	latitude, longitude
Temperature	DS18B20	Type/range/plausibility checks	temperature
Sensor status	ESP32 diagnostics	Heartbeat + connectivity + sensor health	sensor_status, device_status

4. IoT Device Security

The smart bin is treated as an untrusted edge endpoint. Registration alone does not make it trusted. Trust is established progressively through identity, secure transport, validation and least privilege.

Layer	Control	How it secures the device
Identity	Unique device_id + protected key/certificate	Backend accepts telemetry only for registered, active identities.
Cryptography	ATECC608A / protected key material	Device private key is intended to remain protected by secure hardware rather than source-code constants.
Transport	TLS-protected MQTT/HTTPS	Protects telemetry in transit from interception and modification.
Message validation	Schema + type + range checks	Prevents authenticated devices from sending arbitrary values.
Freshness	Timestamp + sequence/message identifier	Helps detect stale or replayed telemetry.
Location integrity	Bounds + historical consistency	Flags impossible or suspicious geographic movement.
Lifecycle	Activate / revoke / rotate credentials	A compromised device can be blocked without changing the whole platform.
Least privilege	Device may submit its own telemetry only	IoT identity has no route-management or administrator authority.
Monitoring	Authentication failures + anomalies + device health	Turns suspicious device behavior into auditable events/alerts.
Physical security	Protected electronics compartment	Reduces direct tampering with controller and secure element.

4.1 Secure Telemetry Sequence

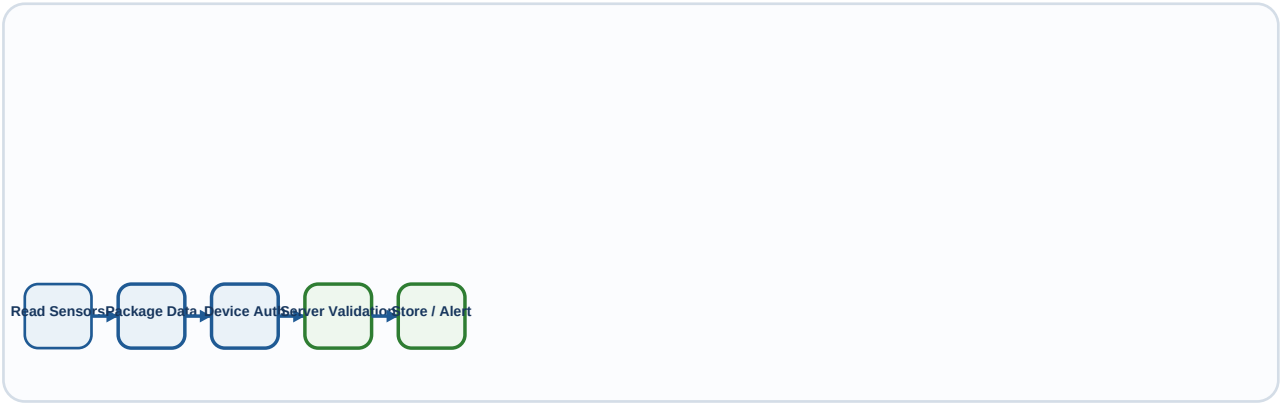

Figure 2. Device data is not allowed to influence route generation until authentication and server-side validation succeed.

Technical pitch for faculty: "Each smart bin has a unique device identity. Telemetry is sent through a TLS-protected channel, the backend authenticates the device, validates fill level, location, temperature, timestamp and sensor status, checks for anomalous or replayed values, and only then stores the data for route optimization. The device itself follows least privilege and cannot modify routes or access administrative APIs."

5. Secure System Architecture

A layered modular architecture separates presentation, API entry, identity enforcement, domain services, data access and persistence. Route optimization is isolated as a controlled business capability, while audit/security monitoring is handled as a dedicated service.

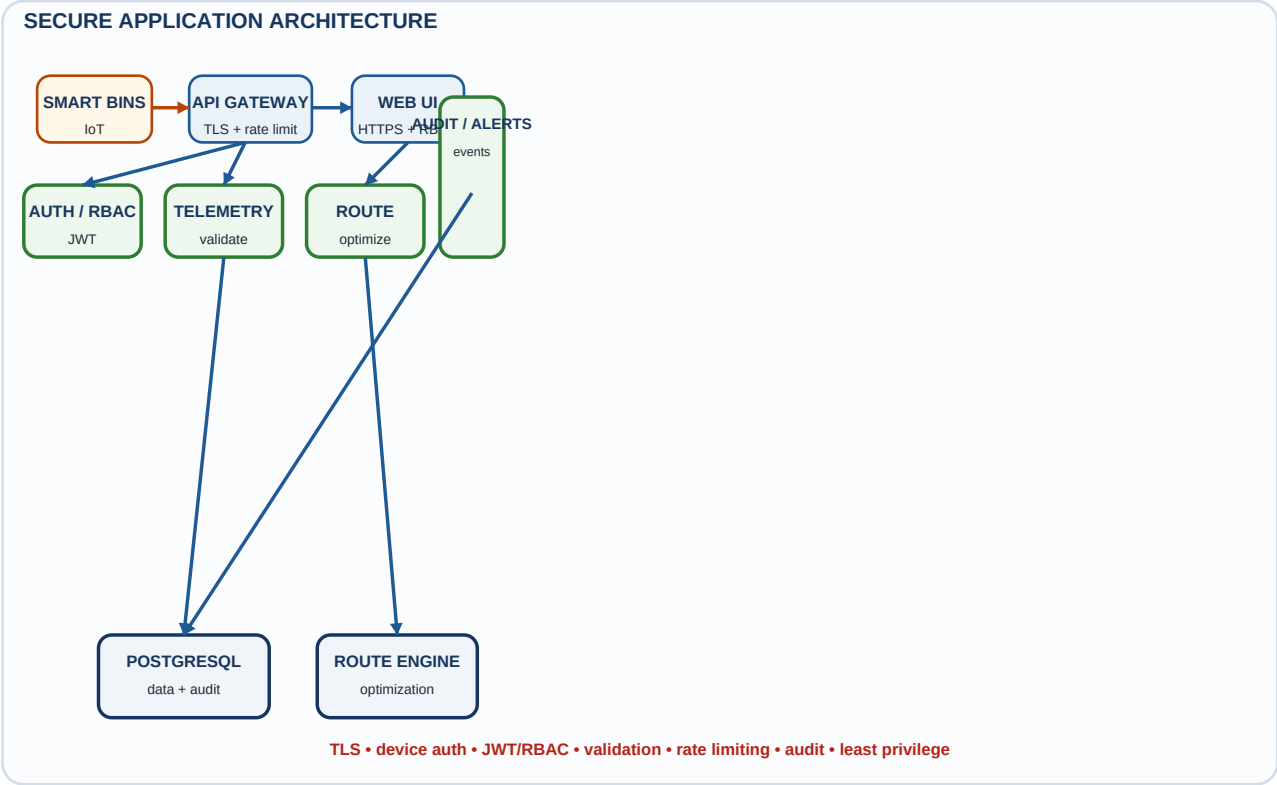

Figure 3. Secure SmartWaste architecture and protected data path.

Component	Responsibility	Primary Control
Web UI	Dashboard, route management, bin monitoring.	HTTPS; role-aware navigation.
API Gateway	Controlled application entry point.	TLS, rate limiting, request controls.
Authentication & RBAC	Identity and permission enforcement.	JWT/session validation; role/permission checks.
Telemetry Service	Validate and persist device telemetry.	Schema/range/consistency validation.
Route Service	Generate, version and assign routes.	Authorization, validation, version checks.
Audit & Alert Service	Record security events and monitor anomalies.	Controlled writes, monitoring and alerts.
PostgreSQL	Persistent application/audit data.	Least-privilege account, protected network.
Route Engine	Optimize collection sequence.	Validated input; controlled invocation.

6. ER / Data Model

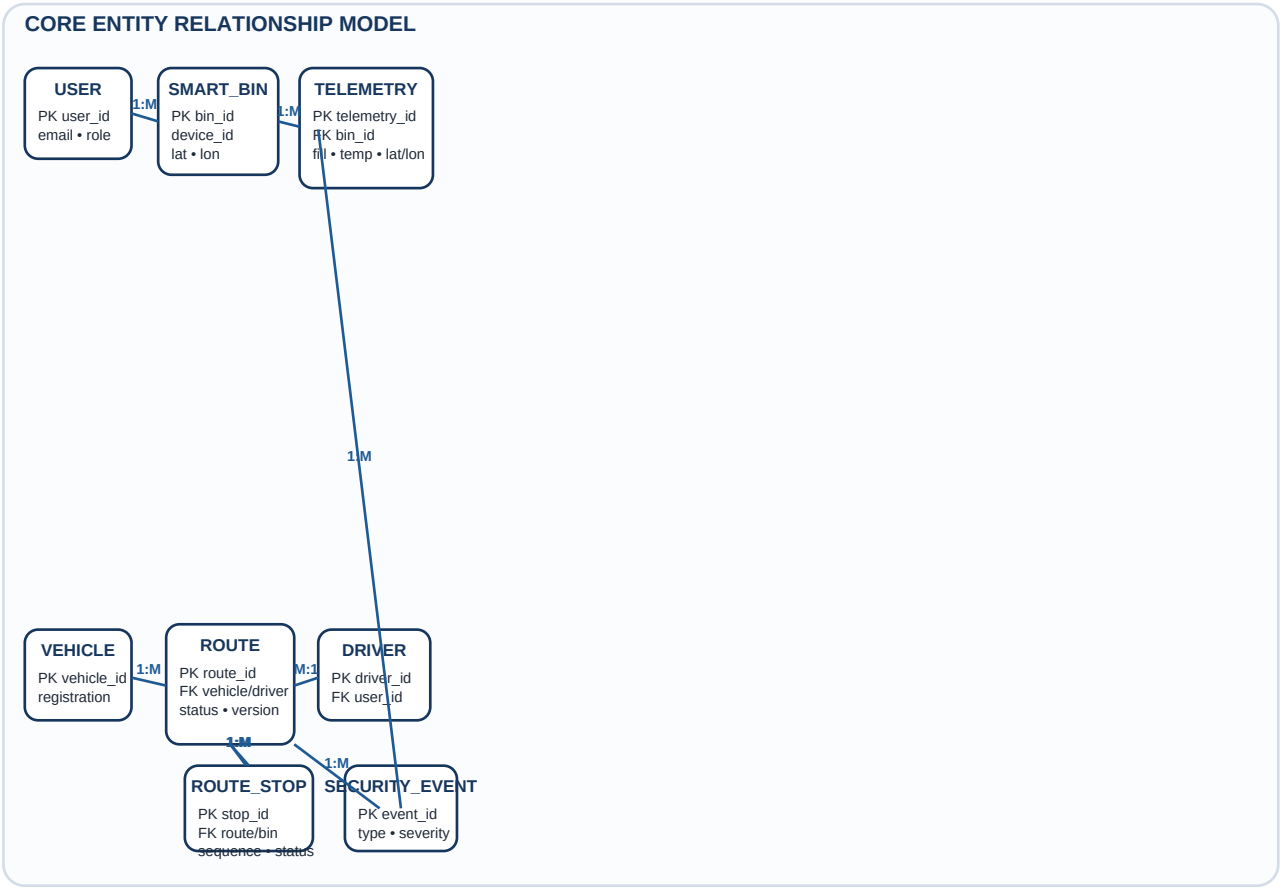

Figure 4. Core persistent entities and cardinality baseline.

The core entities are USER, SMART_BIN, TELEMETRY, SECURITY_EVENT, VEHICLE, ROUTE, DRIVER and ROUTE_STOP. The same vocabulary should be used in the SQL schema, API models, DFD data stores and later implementation.

7. Data Flow Diagrams

7.1 DFD Level 0 - Context

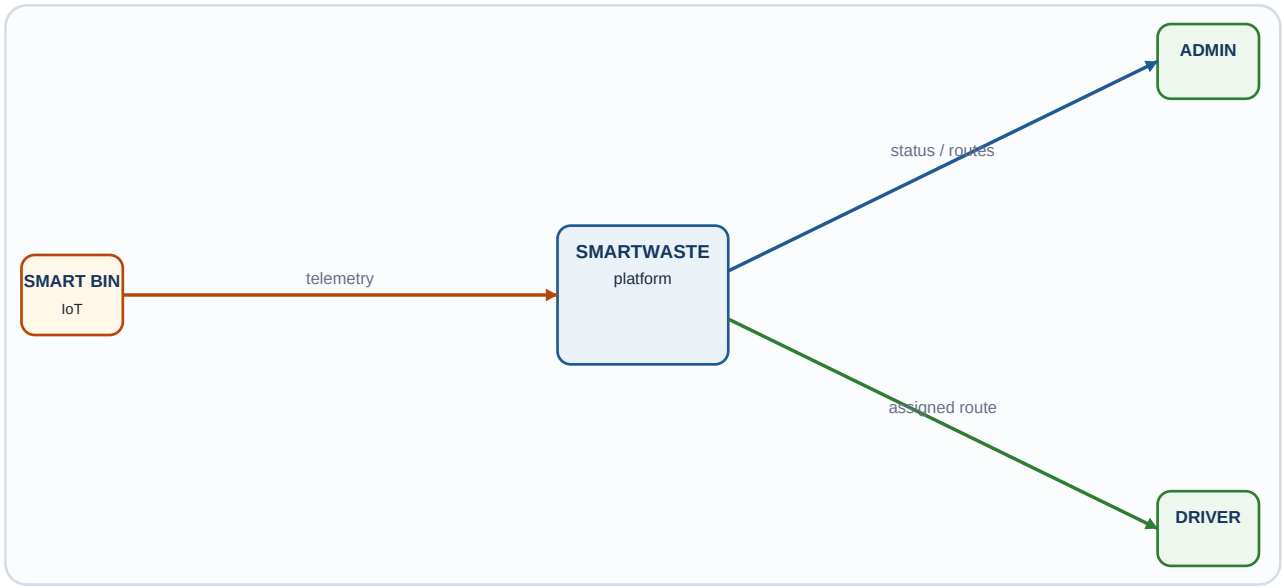

Figure 5. Level-0 context: smart bins, administrator and driver interact with the SmartWaste platform.

7.2 DFD Level 1 - Process Decomposition

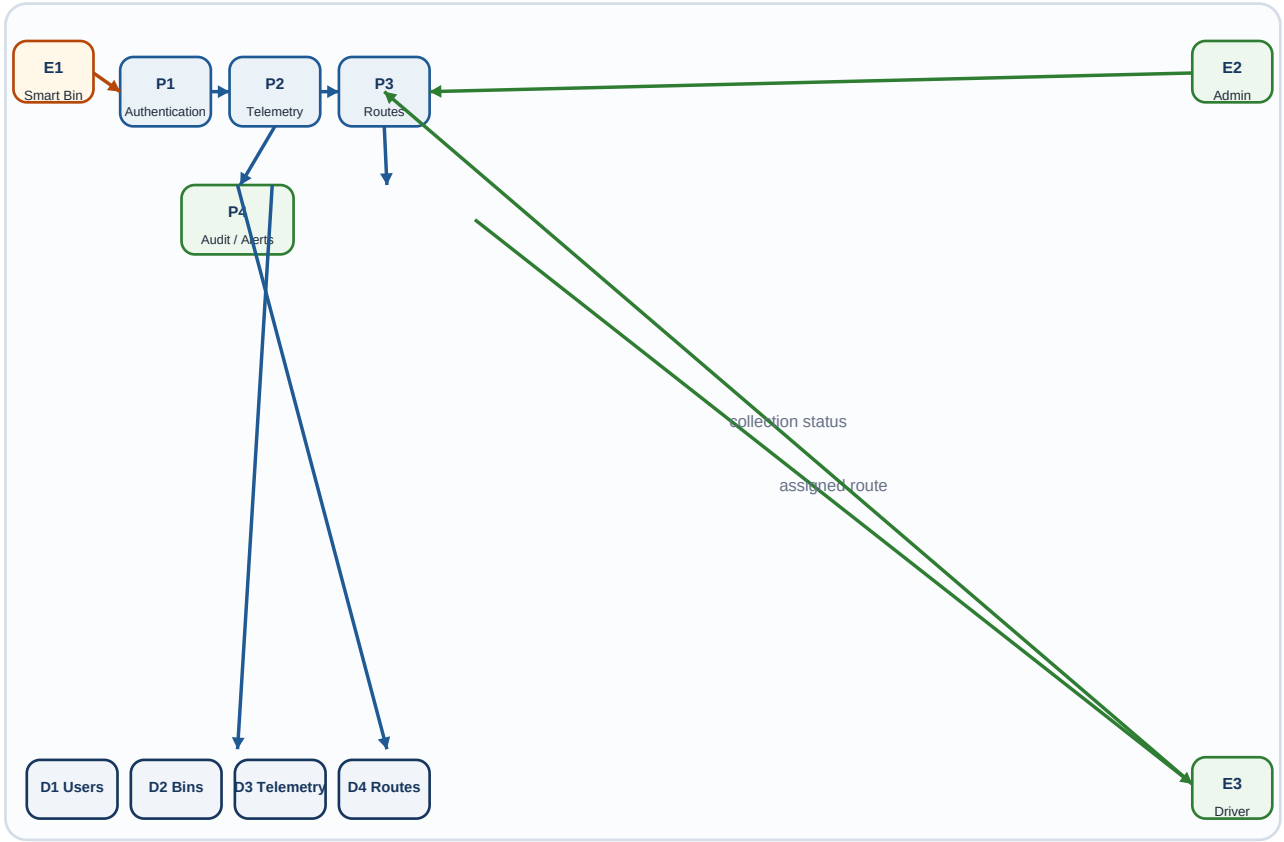

Figure 6. Level-1 decomposition: authentication, telemetry, route management and audit/security processing.

8. Trust Boundaries

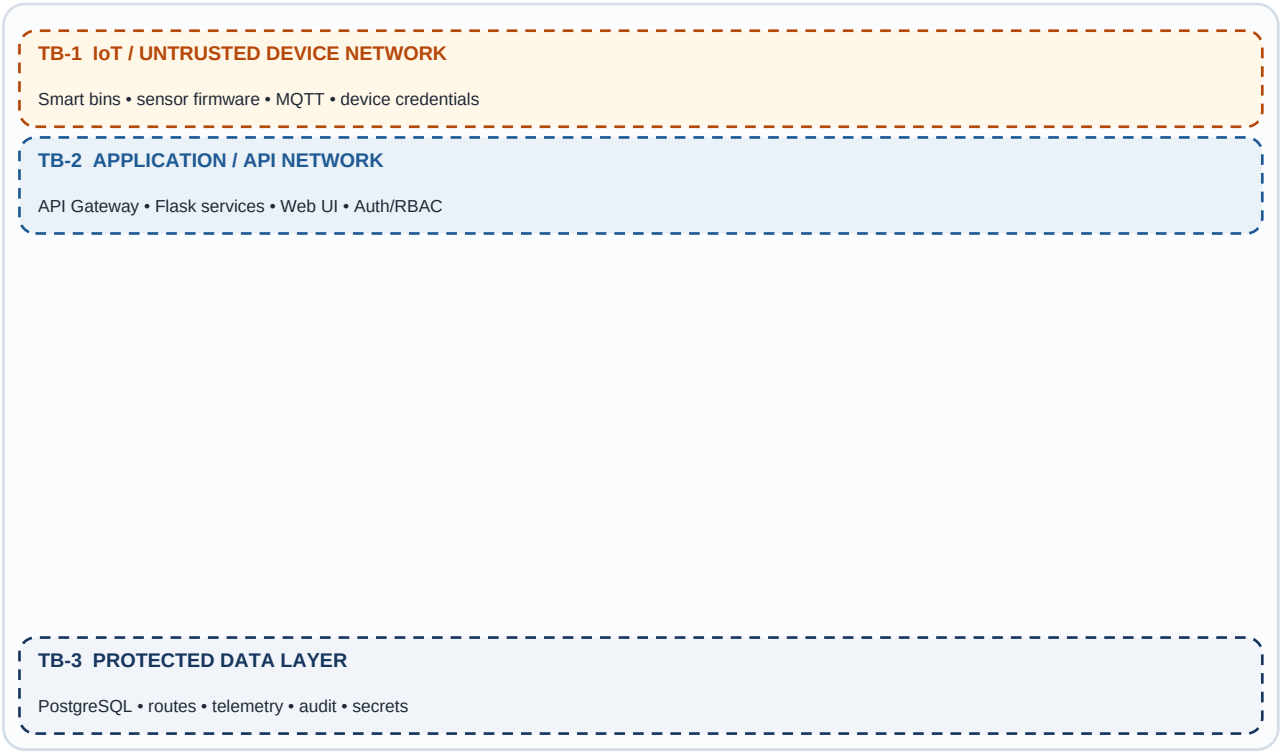

Figure 7. Trust boundaries separating IoT ingress, application/API processing and protected data.

Boundary	Crossing	Primary Risks	Controls
TB-1	IoT → API/application	Spoofing, telemetry tampering, replay, flooding.	TLS, device authentication, validation, sequence checks, rate limiting.
TB-2	Browser → API	Credential abuse, broken authorization, API attacks.	TLS, JWT/RBAC, validation, rate limiting, audit logging.
TB-3	Application → database	Unauthorized reads/writes, secret exposure.	Least privilege, parameterized queries, network restrictions, secret management.
TB-4	Application → runtime	Excess privilege, exposed services.	Non-root containers, restricted ports, resource limits, restricted exposure.

8.1 Critical Information Flows

Flow	Path	Security Objective
IF-01	Smart Bin → API → Telemetry Service → Store	Protect device identity and telemetry integrity.
IF-02	Admin → API → RBAC → Route Service → Store → Audit	Prevent unauthorized route changes.
IF-03	Route Service → Driver	Expose only authorized assigned route data.
IF-04	Security services → Audit/Monitoring	Preserve evidence of failures, anomalies and privileged actions.

9. Security Design Controls & Traceability

Risk / Requirement	Control	Verification Evidence
Sensor spoofing / SR-01	Unique device identity + authentication.	Valid vs unknown/revoked device test.
Location manipulation / SR-05	Coordinate validation + anomaly detection.	Impossible/suspicious location test.
Route modification / SR-06	JWT + RBAC + object-level authorization + audit.	Driver update attempt → 403 + audit event.
Availability / SR-07	Rate limiting + runtime resource limits + health checks.	Abuse/rate-limit test and health observation.
Secret exposure / SR-08	Externalized secrets.	Secret scan; no secrets in repository.
API security / SR-02, SR-04	TLS + validation + safe errors.	SAST and negative API tests.
Auditability / SR-10	Structured security events.	Security event generated after sensitive action.

9.1 Critical Traceability Example

SR-06 Route authorization → Modify Route use case → P3 Route Management in DFD → Unauthorized Route Modification threat → IDOR / missing object-level authorization → implementation with JWT + RBAC → negative authorization test → deployment control with RBAC + audit logging.

9.2 Acceptance Criteria

ID	Criterion
AC-01	Registered device can submit telemetry and the reading appears in the platform.
AC-02	Unknown or revoked device is rejected and a security event is recorded.
AC-03	Invalid fill level or impossible location is rejected.
AC-04	Only authorized administrator can modify a route; unauthorized role receives 403.
AC-05	Route modification creates an audit event with actor, resource and timestamp.
AC-06	API abuse is rate-limited and responses do not expose secrets/stack traces.
AC-07	Application runs as a non-root Docker container.
AC-08	Kubernetes deployment applies non-root security context and resource limits.

10. Phase Alignment / Submission Baseline

Exam Activity	Covered in this document	Carry-forward use
Phase 2 - Requirements Engineering	Stakeholders, FR/NFR/security requirements, CIA focus, authentication/authorization/audit.	Baseline for UML and backlog.
Phase 4 - Data & Information Flow	ER model, DFD Level 0/1, trust boundaries, critical flows.	Baseline for STRIDE/threat modeling.
Phase 5 - Architecture & Design	Secure architecture, components, interfaces and controls.	Baseline for implementation and deployment.
Phase 7 - Threat Modeling input	Asset/CIA inventory and security control mapping.	Baseline for STRIDE/vulnerability/attack tree.

Final Design Baseline

Authenticated Smart Bins → validated telemetry → protected storage → route optimization → authorized vehicle/driver assignment → audited operations. Security is applied at every trust boundary rather than only at the user interface.

Hardware baseline

ESP32-WROOM + HC-SR04 + NEO-6M GPS + DS18B20 + ATECC608A secure element + protected power/enclosure, with Mosquitto MQTT and the SmartWaste Flask/PostgreSQL backend as the laboratory platform.

Document basis

The examination instructions require a concise SRS/requirements table in Phase 2, ER + DFD with trust boundaries in Phase 4, architecture/component design in Phase 5, and asset/CIA, STRIDE and information-flow analysis in Phase 7. Cross-phase consistency and traceability are explicitly part of assessment.